OPEN INTELLIGENCE CASEBOOK

XZ Utils - comprendre une compromission logicielle - Case 04

Emeline Cartier — Open Intelligence Casebook

Présentation clarifiée — 13 novembre 2026

Commencez par l'introduction. Les sources et les limites vous permettent ensuite de vérifier le raisonnement.

Sommaire

Avant de commencer 3

Les mots utiles 3

Case 04 - XZ Utils / CVE-2024-3094 : rapport public 4

Rapport documenté 5

Révision du 2026-10-30 5

Révision du 2026-11-01 5

1. Objectif et périmètre 6

2. Méthode de collecte 6

Résumé pour comprendre la situation 7

Principaux constats 7

MITRE ATT&CK 8

Faits documentés 8

Hypothèses concurrentes 11

Chronologie 12

Évaluation des sources 16

Contradictions conservées 19

Périmètre concerné selon les distributions 21

Niveaux de confiance 21

Limites 22

Inconnues et informations manquantes 23

Vérifications recommandées 23

Revue critique indépendante 24

Sources 25

Avant de commencer

La question en langage courant. Comment un logiciel diffusé largement a-t-il pu contenir un mécanisme malveillant, et que peut-on reconstituer à partir des sources publiques ?

L'idée à retenir. Les sources établissent la compromission de versions précises et un mécanisme soumis à certaines conditions techniques. Elles ne démontrent pas une exploitation réelle ni l'identité du responsable.

Ce qui a été fait. Le dossier reconstitue une chronologie, compare les situations des distributions Linux et conserve les contradictions entre sources. Il repose sur la lecture de documents ; le mécanisme malveillant n'a pas été exécuté par le projet.

Statut. Étude finalisée et publiée dans son périmètre, révisée sur le fond le 1er novembre 2026. L'identité réelle et l'exploitation effective restent non établies.

Les mots utiles

- **XZ Utils / liblzma** : logiciel et bibliothèque de compression concernés par le dossier.
- **Chaîne d'approvisionnement logicielle** : étapes et acteurs qui produisent et distribuent un logiciel.
- **Release / tarball** : version publiée / archive distribuée de cette version.
- **Build** : processus qui transforme les sources en logiciel utilisable.
- **Backdoor** : mécanisme malveillant d'accès dissimulé, souvent traduit par « porte dérobée ».
- **CVE** : identifiant public d'une vulnérabilité ; ici CVE-2024-3094.
- **SSH** : protocole d'accès distant sécurisé ; son interaction avec la bibliothèque compromise dépend de conditions précises.

Pour lire les conclusions. Présence d'une version, présence du code malveillant dans le logiciel construit et exploitation réelle sont trois questions distinctes. Les tableaux les séparent.

Parcours. Lire le résumé et les principaux constats, puis la chronologie et les limites. Les sources, le registre des preuves et les extraits vérifiables permettent d'approfondir. La présentation a été clarifiée le 13 novembre 2026 ; le corps analytique et ses niveaux de confiance sont conservés.

Case 04 - XZ Utils / CVE-2024-3094 : rapport public

> **Édition publique.** Ce rapport reprend le dossier OSINT d'origine. Transformations de l'édition publique : retrait d'une section interne d'évaluation de l'espace de travail, retrait des URL d'avatar dans les extraits S-008/S-009, et libellé générique des outils de collecte. Une introduction pédagogique, des titres français et une présentation en fiches des tableaux larges ont été ajoutés le 13 novembre 2026. Aucun fait, jugement ou niveau de confiance n'est modifié.

> **Case ID :** `OSINT-XZ-UTILS-2026-001` **Nature :** investigation OSINT publique, passive et non intrusive. **Collecte :** consultation de pages publiques uniquement ; aucune connexion à une cible, aucun scan, aucun compte, aucun credential et aucune donnée personnelle inutile. **Date de collecte :** `2026-08-21T15:51:32+02:00` — UTC normalisé : `2026-08-21T13:51:32Z`. **Artifacts :** `source-extracts.md` et `citations-ledger.json` dans le même dossier.

Rapport documenté

Révision du 2026-10-30

Réétude du dossier à partir de cinq sources complémentaires ([13] à [17]) et de trois citations ajoutées à [11]. Les faits F-001 à F-012 sont conservés ; aucun niveau de confiance n'est relevé sans source nouvelle. Principaux apports :

- **Chronologie longue (2021–2024)** : la compromission ne commence pas en février 2024 ; une compilation sourcée décrit plus de deux ans de contributions puis l'accès en écriture et la maintenance de releases (F-013, F-014).[13]
- **C-001 réconciliée** : le 28 mars correspond à la découverte et à la notification privée, le 29 mars à la divulgation publique (F-015).[13][2][17]
- **C-003 résolue au niveau documentaire** : le déclencheur M4 n'existe que dans les tarballs, la charge de second niveau est dans des fichiers de test du dépôt Git (F-016).[11][13][14]
- **Capacité technique requalifiée** : l'accès est conditionné à une signature Ed448 détenue par l'attaquant ; c'est une exécution de commande pré-authentification réservée au détenteur de la clé, pas un contournement d'authentification utilisable par n'importe qui (F-017).[15]
- **Matrice d'exposition par distribution** : Arch Linux, openSUSE / SUSE ajoutés à Debian et Red Hat ; distinction entre version présente, code malveillant effectivement compilé et sshd réellement lié à liblzma (F-018, F-019).[16][17]
- **Sévérité officielle** : CVSS 3.1 de 10.0 (CRITICAL), attribué par la NVD et par le CNA Red Hat (F-020).[14]

Révision du 2026-11-01

Les deux lacunes de collecte laissées par la révision précédente sont comblées sur sources primaires ([18] à [21]) :

- **Ubuntu ajouté à la matrice d'exposition** : selon l'équipe sécurité d'Ubuntu, la version touchée n'a été que dans `noble-proposed` et a été retirée avant d'atteindre noble ; aucune version publiée d'Ubuntu n'est affectée. L'historique de publication de Launchpad date ce passage du 26 février au 29 mars 2024 et montre que les copies vers la poche de publication, créées le 28 mars, n'ont jamais été publiées (F-021).[18][19]
- **Chronologie longue revérifiée** : les quatre jalons tirés de [13] (premier correctif, accès en écriture, première release, fichiers de test piégés) sont confirmés à la seconde près, avec leur fuseau, par l'archive de la liste xz-devel et par les métadonnées du dépôt Git (F-022).[20][21] Les heures des tags v5.6.0 et v5.6.1 sont désormais normalisées en UTC.

1. Objectif et périmètre

Question analytique : que permettent d'établir les sources publiques sur la chronologie de la compromission de XZ Utils, sa découverte, sa portée technique et la réponse de l'écosystème, sans dépasser les preuves disponibles concernant l'intention, l'identité ou l'attribution ?

Périmètre inclus :

- XZ Utils / liblzma et les versions 5.6.0 et 5.6.1 ;
- découverte publique, mécanisme décrit par les sources et réponse des distributions ;
- sources officielles, techniques et secondaires publiquement accessibles ;
- période historique 2024, avec vérification de l'état des pages consultées le 21 août 2026.

Périmètre exclu :

- attribution à un État, groupe ou personne réelle ;
- identification ou investigation de personnes privées derrière des pseudonymes ;
- exploitation, reproduction du backdoor, scan ou test d'une infrastructure ;
- recherche de compromission sur des systèmes réels ;
- collecte de données personnelles non nécessaires.

Réponse satisfaisante : produire une chronologie sourcée, distinguer les faits techniques des analyses, comparer la portée annoncée aux périmètres réellement documentés, expliciter les contradictions et qualifier séparément la fiabilité des sources et la confiance analytique.

---

2. Méthode de collecte

- Recherche web et extraction de pages publiques, en lecture seule.
- Sources enregistrées au moment de la collecte dans `citations-ledger.json`.
- Extraits verbatim conservés dans `source-extracts.md`.
- Hash SHA-256 de `source-extracts.md` dans le dossier de travail d'origine : `3f27ee7c0a69236dc32bfc052f6a0d79a5ab52f0ae382dae09891fa262639e48` (état du 2026-11-01 ; la valeur précédemment indiquée, `c06370b5…45fb`, ne correspondait plus au fichier d'origine depuis la révision du 2026-10-30). La copie publique diffère uniquement par l'assainissement décrit en tête de ce rapport.
- Les sources ont été classées comme officielles, techniques primaires, secondaires ou synthèses d'organisations de sécurité.
- Les dépendances entre sources ont été conservées : notamment OpenSSF, Microsoft, Datadog et Ars Technica citent ou reprennent des éléments issus de l'alerte initiale et d'analyses techniques publiques.
- **Collecte complémentaire du 2026-10-30** : cinq pages publiques supplémentaires ([13] à [17]) et la page Red Hat [11] relue, par extraction de pages en lecture seule ; extraits ajoutés à `source-extracts.md` et au ledger. La page Ubuntu `ubuntu.com/security/CVE-2024-3094` a répondu HTTP 503 et n'est pas utilisée. Le dépôt xzbot [15] est lu comme documentation : aucun code n'est exécuté, aucune clé ni commande n'est reproduite.

- **Collecte complémentaire du 2026-11-01** : page Ubuntu [18] relue (lisible), historique de publication de `xz-utils` pour noble via l'API publique de Launchpad [19], métadonnées du dépôt Git XZ [20] et archive de la liste xz-devel [21]. Le dépôt Git a été cloné **sans aucun contenu de fichier** (`git clone --filter=blob:none --no-checkout`) : seules les métadonnées des commits et des tags ont été lues ; les fichiers de test piégés n'ont été ni téléchargés ni exécutés.

Résumé pour comprendre la situation

Les sources publiques convergent fortement sur l'existence d'une compromission de la chaîne de publication de XZ Utils affectant les versions 5.6.0 et 5.6.1. CISA, Debian et le projet XZ identifient ces versions comme compromises ou à risque, tandis que Debian documente un périmètre principalement situé dans les branches testing, unstable et experimental, et indique qu'aucune version stable Debian n'était alors connue comme affectée.[1][3][5]

La découverte publique est associée à l'observation d'anomalies de performance et de validation sur Debian Sid, décrite dans le message technique d'Andres Freund publié le 29 mars 2024 à 08:51:26 UTC−07:00. Les sources secondaires parlent parfois d'une découverte le 28 mars ; cette différence doit être conservée comme une différence entre observation, analyse et divulgation, et non lissée en une date unique.[2][6][7]

Les éléments disponibles soutiennent avec une confiance élevée l'existence d'un code malveillant introduit dans le processus de publication/build et une capacité de compromission d'OpenSSH dans certaines conditions. Ils ne permettent pas d'établir avec le même niveau de confiance l'identité réelle de l'auteur, le nombre d'acteurs, la motivation exacte ou une attribution étatique. OpenSSF indique explicitement que la motivation reste inconnue, et Ars Technica rappelle que l'existence d'une personne réelle derrière le pseudonyme Jia Tan n'est pas établie.[4][12]

Principaux constats

1. **Versions concernées :** les versions XZ Utils 5.6.0 et 5.6.1 sont identifiées par CISA et le projet XZ comme contenant ou associées au backdoor ; Debian documente des paquets compromis dans ses branches non stables.[1][3][5] **Confiance : HIGH** — plusieurs sources officielles et techniques convergentes.
2. **Chaîne de publication :** les sources techniques décrivent un mécanisme où des éléments du code malveillant sont présents dans les tarballs de release et où le build de paquets DEB/RPM dans certaines conditions produit une bibliothèque liblzma compromise.[2][4][10] **Confiance : HIGH** pour le mécanisme général ; les détails d'exécution restent dépendants des analyses techniques.
3. **Découverte :** Andres Freund rapporte des symptômes inhabituels autour de liblzma sur Debian Sid et publie son analyse sur oss-security le 29 mars ; une compilation sourcée situe la découverte et la notification privée à Debian et à la liste distros le 28 mars.[2][13] **Confiance : HIGH** pour le contenu de son propre rapport ; **MEDIUM-HIGH** pour la séquence 28 mars (notification privée) → 29 mars (divulgation publique), qui repose sur une compilation secondaire, la liste distros n'étant pas publique.

4. **Portée réelle :** les sources ne justifient pas l'affirmation simplifiée selon laquelle toutes les distributions Linux ou toutes les installations de production étaient compromises. Debian indique que les versions stables n'étaient pas connues comme affectées, Red Hat que RHEL n'était pas affecté ; Arch Linux indique que le code n'a pas été injecté dans ses binaires et que sshd n'y est pas lié à liblzma ; openSUSE situe l'exposition dans Tumbleweed et MicroOS (7–28 mars) et l'exclut pour SUSE Linux Enterprise et Leap.[5][11][16][17] **Confiance : HIGH** pour chacun de ces périmètres ; l'exposition dépend de trois conditions cumulées — version présente, code effectivement compilé (paquets DEB/RPM x86-64), sshd lié à liblzma via libsystemd — et ne s'extrapole pas aux distributions non documentées.
5. **Capacité technique :** les analyses décrivent une interférence avec le processus d'authentification SSH permettant une exécution de commande pré-authentification ; l'analyse du binaire montre que la charge doit être chiffrée et signée avec une clé Ed448 de l'attaquant, ce qui réserve la capacité au détenteur de cette clé.[2][7][10][12][15] **Confiance : HIGH** pour la capacité réservée au détenteur de la clé (mécanisme décrit et reproduit en laboratoire avec une clé substituée) ; **LOW** pour toute exploitation réelle, qui n'est pas démontrée. Une exploitation réussie ne produisant pas d'entrée de journal de niveau INFO ou supérieur, l'absence de traces n'établit pas l'absence d'exploitation.[15]
6. **Attribution :** les sources soutiennent une insertion malveillante et une préparation structurée, mais ne permettent pas d'identifier un acteur réel ou un État avec une confiance suffisante.[4][12] **Confiance : LOW** pour toute attribution spécifique.
7. **Préparation longue :** l'opération s'inscrit dans plus de deux ans de contributions publiques (premier correctif en octobre 2021, accès en écriture établi fin 2022, première release produite par le même compte en mars 2023), accompagnées de messages de pression envoyés par des comptes qui n'apparaissent nulle part ailleurs selon les observations rapportées.[13][20][21] **Confiance : HIGH** pour les jalons datés, revérifiés le 2026-11-01 sur l'archive xz-devel et les métadonnées Git ; MEDIUM-HIGH pour les messages de pression, non revérifiés.

MITRE ATT&CK

Aucun mapping MITRE ATT&CK n'est retenu dans ce dossier. Les sources publiques décrivent un incident de chaîne d'approvisionnement et un mécanisme technique, mais ce cas ne dispose pas de télémétrie adversaire ou de séquence d'actions observées permettant de justifier un mapping précis sans surinterprétation.

Faits documentés

ID	Fait	Provenance	Confiance
F-001	CISA rapporte du code malveillant intégré dans XZ Utils 5.6.0 et 5.6.1 et associe l'activité à CVE-2024-3094.	S-001 / [1]	HIGH — alerte gouvernementale directement consultée.

ID	Fait	Provenance	Confiance
F-002	Le projet XZ indique que les tarballs de release 5.6.0 et 5.6.1 contiennent un backdoor.	S-003 / [3]	HIGH — déclaration officielle du projet, avec biais possible sur la gestion de crise.
F-003	Le message d'Andres Freund décrit des symptômes inhabituels autour de liblzma sur Debian Sid, dont une consommation CPU élevée lors de connexions SSH et des erreurs Valgrind.	S-002 / [2]	HIGH — rapport technique primaire pour les observations de l'auteur.
F-004	La page GitHub de release affiche un tag v5.6.0 par JiaT75 le `24 Feb 08:22` et un tag v5.6.1 par JiaT75 le `09 Mar 08:16` ; le fuseau horaire n'est pas fourni par l'extrait.	S-008, S-009 / [8][9]	HIGH pour les métadonnées affichées ; MEDIUM pour toute conversion temporelle ou interprétation de rôle.
F-005	Debian indique que les paquets compromis concernaient testing, unstable et experimental, tandis qu'aucune version stable Debian n'était alors connue comme affectée.	S-005 / [5]	HIGH — advisory Debian signé et spécifique à son périmètre.
F-006	Red Hat indique que RHEL n'est pas affecté dans son advisory et distingue le statut de Fedora 40 beta et Fedora Rawhide.	S-011 / [11]	HIGH pour la position Red Hat ; périmètre limité aux produits Red Hat décrits.
F-007	OpenSSF indique que la motivation reste inconnue, tout en décrivant une intention de compromettre certaines distributions et certaines conditions de build.	S-004 / [4]	MEDIUM-HIGH — synthèse experte, dépendante en partie de sources techniques antérieures.
F-008	Microsoft situe l'identification du backdoor au 28 mars 2024 ; Datadog situe également la découverte au 28 mars, tandis que le rapport public d'Andres Freund est horodaté le 29 mars.	S-006, S-007, S-002 / [6][7][2]	HIGH pour l'existence de ces formulations ; MEDIUM pour leur réconciliation chronologique.
F-009	CERT-EU décrit une capacité pré-authentification dans certaines conditions et identifie plusieurs distributions de test ou de développement comme concernées, tout en signalant que sa liste n'est pas exhaustive.	S-010 / [10]	MEDIUM-HIGH — advisory officiel mais rédigé pendant une phase d'analyse évolutive.
F-010	Ars Technica rapporte que le code permettrait, sous certaines conditions, de faire passer une commande via un mécanisme SSH, mais précise qu'aucun code n'a été observé comme effectivement téléversé et que l'identité réelle derrière Jia Tan reste inconnue.	S-012 / [12]	MEDIUM — source secondaire crédible, mais dépendante d'analyses externes et de déclarations de chercheurs.

ID	Fait	Provenance	Confiance
F-011	Les sources consultées sont historiques et leur fraîcheur ne signifie pas que les pages ou les conclusions ont la même date de mise à jour : OpenSSF, Microsoft, Datadog et CERT-EU présentent des mises à jour distinctes.	S-004, S-006, S-007, S-010 / [4][6][7][10]	HIGH — observable dans les métadonnées des pages.
F-012	La collecte de ce dossier est passive et limitée à des sources publiques ; aucun système cible, compte ou donnée personnelle privée n'a été investigué.	Journal de collecte local	HIGH — action effectivement réalisée.
F-013	Une chronologie sourcée décrit un contributeur sous le nom « Jia Tan » actif pendant plus de deux ans, du premier correctif (2021-10-29) à l'obtention d'un accès en écriture et de la maintenance.	S-013, S-020, S-021 / [13][20][21]	HIGH — jalons revérifiés sur sources primaires le 2026-11-01 (F-022).
F-014	La même chronologie date l'insertion de fichiers de test binaires contenant le code caché au 2024-02-23, la première release produite par ce compte (v5.4.2) au 2023-03-18, et indique que l'accès en écriture est établi au 2022-12-30.	S-013, S-020 / [13][20]	HIGH — dates confirmées, avec heure et fuseau, par les métadonnées Git (F-022).
F-015	La découverte et la notification privée à Debian et à la liste distros@openwall sont datées du 2024-03-28 ; Red Hat attribue la CVE le même jour ; la divulgation publique suit le 29 mars. openSUSE confirme que le signalement a d'abord été adressé à Debian.	S-013, S-002, S-017 / [13][2][17]	MEDIUM-HIGH — la liste distros n'est pas publique ; séquence cohérente entre trois sources de lignées différentes.
F-016	Red Hat indique que l'injection n'est complète que dans le paquet téléchargé : la distribution Git ne contient pas la macro M4 déclencheuse, mais contient les artefacts de second niveau ; la NVD décrit l'extraction d'un objet précompilé depuis un fichier de test déguisé.	S-011, S-014, S-013 / [11][14][13]	HIGH — deux sources officielles convergentes et une compilation indépendante.
F-017	L'analyse publique du binaire indique que la porte dérobée valide une signature avec une clé publique Ed448 codée en dur et exige une charge chiffrée et signée avec la clé de l'attaquant ; une exploitation réussie ne génère aucune entrée de journal de niveau INFO ou supérieur.	S-015 / [15]	MEDIUM-HIGH — analyse d'un chercheur, reproductible et largement reprise, mais non institutionnelle.
F-018	Arch Linux indique que le code distribué dans le tarball n'a pas été injecté dans ses binaires (le script ne visait que les environnements de build Debian/Fedora) et que sshd n'y est pas lié à liblzma.	S-016 / [16]	HIGH pour le périmètre Arch Linux.
F-019	openSUSE indique que Tumbleweed et MicroOS ont inclus la version compromise du 7 au 28 mars 2024, et que le fichier malveillant n'est pas présent dans SUSE Linux Enterprise ni openSUSE Leap.	S-017 / [17]	HIGH pour le périmètre openSUSE / SUSE.

ID	Fait	Provenance	Confiance
F-020	La NVD affiche un score CVSS 3.1 de 10.0 (CRITICAL), attribué à la fois par la NVD et par le CNA Red Hat.	S-014 / [14]	HIGH — notice officielle ; le score mesure la gravité potentielle, pas une exploitation observée.
F-021	Ubuntu déclare que la version touchée n'a été que dans `noble-proposed`, retirée avant d'atteindre noble, et qu'aucune version publiée n'est affectée. Launchpad enregistre `5.6.0-0.1` (publié le 2024-02-26) puis `5.6.0-0.2` (publié le 2024-02-29) dans `noble-proposed` ; quatre copies vers la poche de publication, créées le 2024-03-28, n'ont jamais été publiées (« Revert to previous version ») ; le remplacement `5.6.1+really5.4.5-1` est publié dans noble le 2024-03-30. Le numéro `5.6.1+really5.4.5` désigne du code 5.4.5 : un contrôle fondé sur la seule chaîne de version produirait un faux positif.	S-018, S-019 / [18][19]	HIGH pour le statut des versions publiées d'Ubuntu ; l'exposition des machines ayant activé `noble-proposed` n'est pas documentée.
F-022	L'archive xz-devel et les métadonnées Git confirment les jalons de [13] : premier correctif envoyé le 2021-10-29 à 11:29:18 −07:00 ; lot de commits enregistré par Jia Tan sur `master` le 2022-12-30 à 23:34:31 +08:00 (commit `8ace358d`) ; tag v5.4.2 le 2023-03-18 à 23:37:16 +08:00 ; commit `cf44e4b7` « Tests: Add a few test files » le 2024-02-23 à 23:09:59 +08:00 ; tags v5.6.0 le 2024-02-24 à 16:22:06 +08:00 et v5.6.1 le 2024-03-09 à 16:16:00 +08:00. Une copie du premier commit, sur la branche `v5.4`, porte une date de committer du 2022-12-16.	S-020, S-021 / [20][21]	HIGH pour les métadonnées ; une date de commit ou de tag est déclarée par l'outil de son auteur et ne prouve pas la date d'un push.

Hypothèses concurrentes

H1 — Compromission délibérée de la chaîne de publication/build

- **Soutien :** tarballs de release compromis, versions successives, code obfusqué, conditions de build ciblées et intervention dans le processus de publication.[2][3][4][10] Révision du 2026-10-30 : plus de deux ans de contributions préalables, accès en écriture puis maintenance des releases, et charge réservée au détenteur d'une clé Ed448 : la préparation est longue et délibérée.[13][15]
- **Affaiblissement :** les sources publiques ne démontrent pas à elles seules le nombre d'acteurs ni toute la chaîne opérationnelle.
- **Test ou information invalidante :** preuve indépendante d'une compromission accidentelle du compte ou d'un artefact de build sans intention malveillante ; les sources retenues ne fournissent pas cette preuve.
- **Confiance : HIGH** pour l'insertion volontaire de code malveillant ; MEDIUM pour la reconstruction complète de la campagne.

H2 — Compromission d’un compte ou d’un environnement de mainteneur sans connaissance complète de l’auteur

- **Soutien :** l’identité réelle derrière le pseudonyme n’est pas établie et les sources ne donnent pas de preuve publique complète sur l’identité opérationnelle.[4][12]
- **Affaiblissement :** la répétition des modifications, la signature de tarballs et les ajustements entre versions sont plus compatibles avec une action structurée qu’avec un incident ponctuel, sans toutefois prouver le modèle exact.
- **Test ou information invalidante :** journaux d’accès, preuves cryptographiques, correspondances d’identité ou éléments d’infrastructure non publics.
- **Révision du 2026-10-30 :** la chronologie sourcée montre que le même compte contribue publiquement depuis 2021, obtient l’accès en écriture puis produit les releases ; l’hypothèse d’un compte légitime compromis à la dernière minute devient peu compatible avec ces observations.[13]
- **Confiance : LOW** — abaissée depuis LOW-MEDIUM ; hypothèse conservée pour mémoire, sans être exclue formellement en l’absence de données non publiques.

H3 — Opération organisée ou soutenue par un acteur étatique

- **Soutien :** durée apparente de préparation, ciblage technique et effort de construction d’une position de confiance ; certaines analyses secondaires évoquent un profil compatible avec une opération très organisée.[7][12]
- **Affaiblissement :** aucune source primaire retenue n’identifie un État, un groupe ou une personne réelle ; OpenSSF indique que la motivation reste inconnue.[4]
- **Test ou information invalidante :** renseignement indépendant et vérifiable reliant l’opération à un acteur identifié.
- **Confiance : LOW** — hypothèse plausible mais insuffisamment étayée ; aucune attribution n’est retenue.

Chronologie

> Les timestamps sont conservés avec le fuseau fourni. Lorsqu’une page n’affiche pas de timezone ou d’heure complète, la normalisation UTC est indiquée comme non disponible.

Premier correctif du compte « Jia Tan » sur la liste xz-devel (`.editorconfig`).

- **Date et heure de la source :** 2021-10-29T11:29:18-07:00
- **Fuseau horaire de la source :** UTC−07:00
- **Date et heure en UTC :** 2021-10-29T18:29:18Z
- **Source :** S-021 / [21] ; S-013 / [13]
- **Statut :** confirmé sur l’archive de la liste

Lot de commits enregistré par Jia Tan sur `master` (commit `8ace358d`) : accès en écriture établi.

- **Date et heure de la source :** 2022-12-30T23:34:31+08:00
- **Fuseau horaire de la source :** UTC+08:00 (déclaré)
- **Date et heure en UTC :** 2022-12-30T15:34:31Z
- **Source :** S-020 / [20] ; S-013 / [13]
- **Statut :** confirmé sur les métadonnées Git ; date déclarée, pas date de push

Première release (tag v5.4.2) produite par ce compte.

- **Date et heure de la source :** 2023-03-18T23:37:16+08:00
- **Fuseau horaire de la source :** UTC+08:00 (déclaré)
- **Date et heure en UTC :** 2023-03-18T15:37:16Z
- **Source :** S-020 / [20] ; S-013 / [13]
- **Statut :** confirmé sur le tag

Ajout de fichiers de test binaires contenant le code caché (commit `cf44e4b7`).

- **Date et heure de la source :** 2024-02-23T23:09:59+08:00
- **Fuseau horaire de la source :** UTC+08:00 (déclaré)
- **Date et heure en UTC :** 2024-02-23T15:09:59Z
- **Source :** S-020 / [20] ; S-013 / [13]
- **Statut :** confirmé sur les métadonnées Git

Tag v5.6.0 par Jia Tan ; l'affichage GitHub `24 Feb 08:22` correspond à l'heure UTC.

- **Date et heure de la source :** 2024-02-24T16:22:06+08:00
- **Fuseau horaire de la source :** UTC+08:00 (déclaré)
- **Date et heure en UTC :** 2024-02-24T08:22:06Z
- **Source :** S-020 / [20] ; S-008 / [8]
- **Statut :** confirmé sur le tag

`xz-utils` 5.6.0 dans `noble-proposed` (Ubuntu), jamais publié dans noble.

- **Date et heure de la source :** 2024-02-26T13:47:39Z → 2024-03-29T06:10:17Z
- **Fuseau horaire de la source :** UTC
- **Date et heure en UTC :** 2024-02-26T13:47:39Z → 2024-03-29T06:10:17Z
- **Source :** S-019 / [19] ; S-018 / [18]
- **Statut :** confirmé sur Launchpad

Tag v5.6.1 par Jia Tan ; l'affichage GitHub `09 Mar 08:16` correspond à l'heure UTC.

- **Date et heure de la source :** 2024-03-09T16:16:00+08:00
- **Fuseau horaire de la source :** UTC+08:00 (déclaré)
- **Date et heure en UTC :** 2024-03-09T08:16:00Z

- **Source :** S-020 / [20] ; S-009 / [9]
- **Statut :** confirmé sur le tag

Version compromise incluse dans openSUSE Tumbleweed et MicroOS.

- **Date et heure de la source :** 2024-03-07 → 2024-03-28
- **Fuseau horaire de la source :** unknown
- **Date et heure en UTC :** not available
- **Source :** S-017 / [17]
- **Statut :** confirmé pour openSUSE

Découverte et notification privée à Debian et distros@openwall ; CVE-2024-3094 attribuée par Red Hat. Date d'identification également rapportée par Microsoft et Datadog.

- **Date et heure de la source :** 2024-03-28 — heure non fournie
- **Fuseau horaire de la source :** unknown
- **Date et heure en UTC :** not available
- **Source :** S-013, S-006, S-007 / [13][6][7]
- **Statut :** rapporté ; cohérent entre lignées distinctes

Publication du rapport technique d'Andres Freund sur oss-security.

- **Date et heure de la source :** 2024-03-29T08:51:26-07:00
- **Fuseau horaire de la source :** UTC−07:00
- **Date et heure en UTC :** 2024-03-29T15:51:26Z
- **Source :** S-002 / [2]
- **Statut :** confirmé

Publication de l'advisory Debian DSA-5649-1.

- **Date et heure de la source :** 2024-03-29T16:09:37+00:00
- **Fuseau horaire de la source :** UTC
- **Date et heure en UTC :** 2024-03-29T16:09:37Z
- **Source :** S-005 / [5]
- **Statut :** confirmé

Publication de l'alerte CISA.

- **Date et heure de la source :** 2024-03-29 — heure non fournie
- **Fuseau horaire de la source :** unknown
- **Date et heure en UTC :** not available
- **Source :** S-001 / [1]
- **Statut :** confirmé comme date de publication

Publication initiale de l’article OpenSSF ; mise à jour affichée au 1er avril.

- **Date et heure de la source :** 2024-03-30 — heure non fournie
- **Fuseau horaire de la source :** unknown
- **Date et heure en UTC :** not available
- **Source :** S-004 / [4]
- **Statut :** confirmé comme métadonnée de page

Publication de la guidance Microsoft ; mise à jour affichée au 7 avril.

- **Date et heure de la source :** 2024-04-01 — heure non fournie
- **Fuseau horaire de la source :** unknown
- **Date et heure en UTC :** not available
- **Source :** S-006 / [6]
- **Statut :** confirmé comme métadonnée de page

Advisory CERT-EU v1.1 ; historique indiquant une v1.0 au 30 mars.

- **Date et heure de la source :** 2024-04-02 — heure non fournie
- **Fuseau horaire de la source :** unknown
- **Date et heure en UTC :** not available
- **Source :** S-010 / [10]
- **Statut :** confirmé

Publication de l’analyse Datadog ; dernière mise à jour affichée au 8 avril.

- **Date et heure de la source :** 2024-04-03 — heure non fournie
- **Fuseau horaire de la source :** unknown
- **Date et heure en UTC :** not available
- **Source :** S-007 / [7]
- **Statut :** confirmé

La page du mainteneur indique la publication de nouvelles releases propres.

- **Date et heure de la source :** 2024-05-29 — heure non fournie
- **Fuseau horaire de la source :** unknown
- **Date et heure en UTC :** not available
- **Source :** S-003 / [3]
- **Statut :** rapporté par le mainteneur

Collecte des pages publiques pour ce dossier.

- **Date et heure de la source :** 2026-08-21T15:51:32+02:00
- **Fuseau horaire de la source :** Europe/Paris / UTC+02:00
- **Date et heure en UTC :** 2026-08-21T13:51:32Z
- **Source :** Journal local et ledger

- **Statut :** confirmé

Évaluation des sources

S-001 CISA

- **Type :** advisory gouvernemental
- **Source primaire / secondaire :** Primary pour la position CISA ; secondary pour l'incident initial
- **Fiabilité :** HIGH
- **Corroboration / dépendance :** Cohérent avec Debian, XZ, Openwall et CERT-EU ; alerte historique
- **Fraîcheur et limites :** 2024-03-29 ; utile pour l'alerte et la recommandation, pas pour l'état courant de toutes les distributions.

S-002 Openwall / Freund

- **Type :** rapport technique primaire
- **Source primaire / secondaire :** Primary
- **Fiabilité :** HIGH pour les observations et l'analyse de l'auteur
- **Corroboration / dépendance :** Source initiale majeure ; plusieurs sources secondaires la citent
- **Fraîcheur et limites :** 2024-03-29 ; l'auteur précise lui-même que certaines parties du mécanisme n'étaient pas encore complètement analysées.

S-003 XZ maintainer

- **Type :** déclaration officielle du projet
- **Source primaire / secondaire :** Primary pour le statut du projet
- **Fiabilité :** MEDIUM-HIGH
- **Corroboration / dépendance :** Corrobore versions et remédiation ; intérêt direct dans la communication de crise
- **Fraîcheur et limites :** Page évolutive ; elle mélange faits historiques et mises à jour ultérieures.

S-004 OpenSSF

- **Type :** synthèse d'experts
- **Source primaire / secondaire :** Secondary
- **Fiabilité :** MEDIUM-HIGH
- **Corroboration / dépendance :** Reprend Openwall, Red Hat et Debian ; dépendance explicite à ces sources
- **Fraîcheur et limites :** Publiée 2024-03-30, mise à jour 2024-04-01 ; utile pour la synthèse, moins forte qu'une preuve technique originale.

S-005 Debian DSA

- **Type :** advisory distribution
- **Source primaire / secondaire :** Primary pour Debian

- **Fiabilité :** HIGH
- **Corroboration / dépendance :** Corrobore versions et périmètre Debian ; source indépendante de la communication Microsoft
- **Fraîcheur et limites :** 2024-03-29 ; périmètre limité à Debian.

S-006 Microsoft

- **Type :** guidance fournisseur
- **Source primaire / secondaire :** Secondary / technical
- **Fiabilité :** HIGH pour les recommandations Microsoft ; MEDIUM pour l'impact global
- **Corroboration / dépendance :** Reprend CISA et advisories des distributions
- **Fraîcheur et limites :** Publiée 2024-04-01, mise à jour 2024-04-07 ; document de réponse, pas une autopsie complète.

S-007 Datadog

- **Type :** analyse fournisseur de sécurité
- **Source primaire / secondaire :** Secondary / technical
- **Fiabilité :** MEDIUM-HIGH
- **Corroboration / dépendance :** Curation explicite de sources externes ; dépend d'Openwall et d'autres analyses
- **Fraîcheur et limites :** Publiée 2024-04-03, mise à jour 2024-04-08 ; utile pour mécanisme, risque de propagation narrative.

S-008/S-009 GitHub releases

- **Type :** métadonnées de dépôt
- **Source primaire / secondaire :** Primary
- **Fiabilité :** HIGH pour les tags affichés ; MEDIUM pour le contexte temporel incomplet
- **Corroboration / dépendance :** Corrobore la séquence des releases ; ne prouve pas à elle seule l'intention
- **Fraîcheur et limites :** Heure et fuseau non affichés dans l'extrait ; année contextualisée mais non répétée par la page.

S-010 CERT-EU

- **Type :** advisory institutionnel européen
- **Source primaire / secondaire :** Primary pour l'advisory ; Secondary pour les détails repris
- **Fiabilité :** HIGH pour la publication ; MEDIUM-HIGH pour les détails techniques en évolution
- **Corroboration / dépendance :** Références Openwall, Red Hat, Debian et autres advisories
- **Fraîcheur et limites :** v1.0 du 30 mars, v1.1 du 2 avril ; signale que la liste des distributions n'est pas exhaustive.

S-011 Red Hat

- **Type :** advisory fournisseur/distribution

- **Source primaire / secondaire :** Primary pour le périmètre Red Hat
- **Fiabilité :** HIGH
- **Corroboration / dépendance :** Corrobore avec Debian la distinction entre branches de développement et systèmes stables ; périmètre spécifique
- **Fraîcheur et limites :** 2024-03-29, mise à jour 2024-03-30 ; conclusions propres à Red Hat/Fedora. L'URL citée redirige depuis vers `…fedora-40-and-rawhide-users` : le titre parle désormais de Fedora Linux 40, ce qui concorde avec F-006.

S-012 Ars Technica

- **Type :** journalisme technique
- **Source primaire / secondaire :** Secondary
- **Fiabilité :** MEDIUM
- **Corroboration / dépendance :** S'appuie sur Freund, Openwall, analyses de chercheurs et advisories
- **Fraîcheur et limites :** Source contemporaine utile pour le contexte ; ne doit pas soutenir seule une attribution.

S-013 Russ Cox, chronologie

- **Type :** compilation chronologique sourcée
- **Source primaire / secondaire :** Secondary (renvoie à des archives primaires)
- **Fiabilité :** MEDIUM-HIGH
- **Corroboration / dépendance :** Lignée propre ; chaque entrée pointe vers une archive xz-devel, un commit git ou un rapport de bug ; reprend aussi S-002
- **Fraîcheur et limites :** Publiée 2024-04-01, mise à jour 2024-04-03 ; dates au jour sans fuseau ; les liens primaires ne sont pas revérifiés un à un ici.

S-014 NIST NVD

- **Type :** notice de vulnérabilité officielle
- **Source primaire / secondaire :** Primary pour la notice et le score
- **Fiabilité :** HIGH
- **Corroboration / dépendance :** Description fournie par le CNA Red Hat ; corrobore S-011
- **Fraîcheur et limites :** Publiée 2024-03-29, dernière modification 2026-06-17 ; le score est une gravité potentielle.

S-015 xzbot

- **Type :** analyse technique de chercheur (rétro-ingénierie)
- **Source primaire / secondaire :** Primary pour l'analyse du binaire
- **Fiabilité :** MEDIUM-HIGH
- **Corroboration / dépendance :** Lignée distincte de S-002 pour le format de la charge ; cite d'autres analyses publiques
- **Fraîcheur et limites :** 2024-04-01 → 2024-04-03 ; démonstration en laboratoire avec une clé substituée, pas une observation d'exploitation réelle.

S-016 Arch Linux

- **Type :** annonce de distribution
- **Source primaire / secondaire :** Primary pour Arch Linux
- **Fiabilité :** HIGH
- **Corroboration / dépendance :** Indépendante de Debian et Red Hat ; reprend S-002 pour le contexte
- **Fraîcheur et limites :** 2024-03-29, mise à jour ultérieure ; périmètre Arch uniquement.

S-017 openSUSE

- **Type :** annonce de distribution
- **Source primaire / secondaire :** Primary pour openSUSE / SUSE
- **Fiabilité :** HIGH pour le périmètre ; MEDIUM pour la description de l'impact
- **Corroboration / dépendance :** Indépendante de Debian et Red Hat
- **Fraîcheur et limites :** 2024-03-29 ; précise que la rétro-ingénierie était alors en cours.

Contradictions conservées

C-001 — 28 mars contre 29 mars

Microsoft et Datadog indiquent le 28 mars comme date d'identification, alors que le message public d'Andres Freund est horodaté le 29 mars à 08:51:26 UTC−07:00.[6][7][2]

Évaluation : il s'agit probablement de jalons différents — observation initiale, analyse privée, notification ou publication — mais les sources retenues ne permettent pas de déterminer exactement quelle étape correspond à chaque date. La contradiction est conservée comme une incertitude chronologique.

Révision du 2026-10-30 — réconciliée (MEDIUM-HIGH) : la chronologie sourcée situe au 28 mars la découverte et la notification privée à Debian et à la liste distros@openwall, et au 29 mars la divulgation publique ; openSUSE confirme que le signalement est d'abord allé à Debian.[13][17] Les deux dates désignent donc deux jalons distincts. L'heure et le jour de la première observation des symptômes restent inconnus : Andres Freund parle lui-même des « dernières semaines ».

C-002 — « Linux largement affecté » contre impact principalement pré-release

Les formulations générales de CISA et de certaines analyses secondaires peuvent donner une impression de compromission généralisée, tandis que Debian précise que stable n'était pas connu comme affecté et Red Hat indique que RHEL n'était pas affecté.[1][5][11]

Évaluation : pas de contradiction directe après segmentation par distribution et canal de publication. La formulation correcte est : **versions compromises publiées ; exposition dépendante de la distribution, du canal, du build et de l'intégration OpenSSH**.

C-003 — Contenu du dépôt contre contenu des tarballs

Openwall décrit une portion du backdoor uniquement présente dans les tarballs et d'autres éléments obfusqués présents dans le dépôt ; Ars Technica résume le mécanisme comme absent du dépôt GitHub et présent dans les tarballs.[2][12]

Évaluation : les formulations semblent viser des étapes différentes de la chaîne : artefacts préparatoires dans le dépôt versus déclencheur/build malveillant dans les tarballs. Il ne faut pas réduire cette nuance à « tout était dans Git » ou « rien n'était dans Git » sans examiner chaque artefact.

Révision du 2026-10-30 — résolue au niveau documentaire (HIGH) : Red Hat précise que la macro M4 déclenchant la construction du code malveillant n'existe que dans le paquet téléchargé, tandis que les artefacts de second niveau sont présents dans le dépôt Git ; la NVD et la chronologie sourcée décrivent un objet précompilé caché dans des fichiers de test binaires du dépôt.[11][14][13] Les deux formulations sont donc exactes pour des étapes différentes. Une comparaison octet par octet des artefacts n'a pas été faite.

C-004 — Capacité technique et exploitation observée

Openwall indique que le mécanisme semblait permettre une forme d'accès ou de RCE pré-authentification, tandis que CERT-EU décrit une capacité de RCE sous conditions ; Ars Technica indique qu'aucun code téléversé n'a été observé.[2][10][12]

Évaluation : il s'agit principalement d'une évolution du niveau d'analyse : capacité théorique ou démontrée par reverse engineering ne signifie pas exploitation réussie dans la nature. Aucune exploitation à grande échelle n'est retenue comme fait.

Révision du 2026-10-30 : l'analyse du binaire précise la nature de la capacité : exécution de commande pré-authentification conditionnée à une charge signée avec la clé Ed448 de l'attaquant.[15] « RCE » et « contournement d'authentification » décrivent donc la même capacité, réservée au détenteur de la clé ; aucune source ne rapporte d'exploitation réelle.

C-005 — Motivation et identité

OpenSSF indique que la motivation reste inconnue ; Ars Technica indique que l'existence d'une personne réelle derrière Jia Tan n'est pas établie, tandis que certaines analyses secondaires évoquent un acteur étatique ou organisé.[4][12]

Évaluation : ce n'est pas une contradiction tranchée mais un conflit de niveaux de preuve. Le dossier conserve l'attribution comme hypothèse LOW et ne la présente pas comme conclusion.

C-006 — « Accès pour des acteurs malveillants » contre accès réservé au détenteur d'une clé

openSUSE écrit, le 29 mars, que la porte dérobée permet à des acteurs malveillants d'accéder aux systèmes exposant SSH, tout en précisant que la rétro-ingénierie est en cours ; l'analyse ultérieure du binaire montre que la charge doit être signée avec la clé Ed448 de l'attaquant.[17][15]

Évaluation : pas de contradiction de fond, mais une différence de date et de précision. Le risque pour les systèmes exposés était réel ; il n'ouvrait pas l'accès à n'importe quel tiers. La recommandation openSUSE de réinstaller reste cohérente avec F-017 : l'exploitation ne laisse pas de trace dans les journaux usuels.

Périmètre concerné selon les distributions

> Trois conditions sont nécessaires à l'exposition : **(1)** une version 5.6.0 ou 5.6.1 présente ; **(2)** le code malveillant effectivement compilé, ce qui exigeait un build de paquet DEB ou RPM x86-64 ; **(3)** un sshd lié à liblzma, en pratique via le patch libsystemd. Une distribution peut remplir (1) sans remplir (2) ou (3).[4][13][16]

Distribution / canal	(1) Version présente	(2) Code compilé	(3) sshd lié à liblzma	Source	Lecture
Debian testing, unstable, experimental	oui	oui (injection observée sur unstable)	oui (sshd patché pour libsystemd)	[5][11] [13]	exposé
Debian stable	non connu	—	—	[5]	non connu comme affecté
Fedora Rawhide	oui (5.6.0 ou 5.6.1)	non précisé	—	[11]	arrêt d'usage demandé par Red Hat
Fedora Linux 40 beta	oui (paquets 5.6.0)	« pas montré compromis »	—	[11]	rétrogradation recommandée
RHEL	non	—	—	[11]	non affecté
openSUSE Tumbleweed, MicroOS	oui (7–28 mars 2024)	non précisé	décrit comme actif dans sshd	[17]	réinstallation recommandée si SSH exposé
SUSE Linux Enterprise, openSUSE Leap	non	—	—	[17]	non affecté
Arch Linux	oui (paquets 5.6.0-1, 5.6.1-1)	non selon Arch	non	[16][13]	vecteur SSH non applicable selon Arch
Ubuntu	`noble-proposed` seulement (5.6.0, 26 févr. → 29 mars 2024) ; aucune version publiée	non précisé	—	[18][19]	non affecté selon Ubuntu ; utilisateurs de `noble-proposed` non documentés

Les cellules « — » ne sont pas renseignées par les sources retenues. Une absence de mention ne vaut pas absence d'exposition.

Niveaux de confiance

Confiance globale : MEDIUM-HIGH.

Justification : les versions, l'existence du code malveillant, la publication du rapport initial, le périmètre Debian et les mesures de réponse sont corroborés par plusieurs sources primaires et techniques. La confiance globale est inférieure à HIGH pour les éléments qui dépendent d'analyses évolutives, de sources secondaires ou d'informations non publiques : première minute de découverte, exploitation réelle, identité et attribution.

Jugement	Confidence	Justification
XZ Utils 5.6.0 et 5.6.1 sont les versions centrales du cas	HIGH	CISA, XZ, Debian et les métadonnées GitHub convergent.
Le mécanisme implique la chaîne de publication/build et liblzma	HIGH	Openwall, OpenSSF, CERT-EU et sources techniques convergent ; détails fins à rattacher aux artefacts correspondants.
L'impact a été limité à certains canaux/distributions et n'est pas équivalent à une compromission universelle	HIGH pour Debian/Red Hat ; MEDIUM pour l'écosystème global	Les sources sont précises pour leurs périmètres mais ne couvrent pas toutes les distributions.
Une exploitation réussie à grande échelle a eu lieu	LOW / non établi	Les sources décrivent une capacité et un risque ; aucune preuve retenue d'exploitation réussie à grande échelle.
La capacité est une exécution de commande pré-authentification réservée au détenteur de la clé Ed448	HIGH	Mécanisme décrit par l'analyse du binaire et reproduit en laboratoire avec une clé substituée ; cohérent avec les advisories.[15]
La compromission résulte d'une préparation de plus de deux ans	HIGH	Jalons datés revérifiés sur l'archive xz-devel et les métadonnées Git (2021-10-29 → 2024-03-09).[13][20][21]
Le 28 mars désigne la notification privée et le 29 mars la divulgation publique	MEDIUM-HIGH	Trois lignées concordantes ; la liste distros n'est pas publique.[13][2][17]
Jia Tan correspond à une personne réelle identifiable	LOW / non établi	Les sources publiques retenues signalent explicitement cette incertitude.
Attribution à un État ou à un groupe précis	LOW / non retenue	Aucun élément primaire suffisant ; hypothèse fondée surtout sur des inférences secondaires.

Limites

- Les pages ont été consultées le 21 août 2026, mais une partie des documents est historique et certains sont évolutifs.
- Les timestamps de plusieurs pages sont seulement des dates sans heure ni timezone.
- Les dates affichées par GitHub pour les releases ne fournissent pas de timezone dans l'extrait collecté ; les métadonnées Git [20] montrent qu'elles correspondent à l'heure UTC (révision du 2026-11-01).

- Les sources secondaires dépendent parfois des mêmes sources primaires ; leur nombre ne constitue donc pas automatiquement un nombre équivalent de sources indépendantes.
- Aucun accès aux journaux de commit complets, aux artefacts binaires originaux, aux logs d'infrastructure ou aux données d'exploitation n'a été réalisé dans ce dossier.
- Les conclusions sur l'intention, l'identité et l'attribution restent limitées par l'absence de données non publiques.
- La collecte web dépend du contenu rendu par les pages au moment de l'accès ; les extraits conservés ne remplacent pas les archives originales.
- Les collectes complémentaires des 2026-10-30 et 2026-11-01 passent par un service d'extraction de pages tiers. La page Ubuntu, illisible le 2026-10-30, a été lue le 2026-11-01 ; la matrice d'exposition ne couvre toujours pas les autres distributions.
- La chronologie longue [13] reste une compilation secondaire ; ses jalons datés ont été revérifiés sur sources primaires le 2026-11-01 [20][21], mais pas les messages de pression ni les autres entrées.

Inconnues et informations manquantes

- Quelle est la date et l'heure exactes de la première observation de l'anomalie ? La notification privée (28 mars) et la publication (29 mars) sont désormais distinguées ; la première observation des symptômes reste non datée.
- Quelle a été l'étendue exacte des paquets distribués et installés dans chaque distribution et canal ?
- Des systèmes de production ont-ils exécuté un build compromis ou exposé un SSH vulnérable ?
- Une exploitation réelle a-t-elle été observée, par qui, quand et avec quels artefacts ?
- Quelle est la chaîne complète d'identités, de comptes et d'infrastructures derrière les pseudonymes ?
- Quelle motivation opérationnelle précise était poursuivie ?
- Quels éléments du backdoor étaient dans le dépôt, les tarballs, les scripts de build et les binaires selon chaque version ?
- Les pages officielles ont-elles été modifiées ou révisées après les dates visibles dans les extraits ?

Vérifications recommandées

1. Pour une analyse historique plus fine, conserver des copies versionnées ou des archives datées des advisories et comparer les versions successives plutôt que de se fier uniquement à la page actuelle.
2. Construire une matrice par distribution, version, canal et méthode de build ; ne pas généraliser le périmètre Debian ou Red Hat à tout Linux.
3. Rattacher chaque affirmation technique à un artefact précis : commit, tarball, script de build, objet compilé ou advisory de distribution.

4. Traiter l'identité et l'attribution comme des intelligence gaps, sauf apparition d'éléments indépendants et vérifiables.
5. Pour un usage défensif, utiliser les recommandations des distributions et de CISA dans un environnement autorisé ; ce dossier ne réalise aucune vérification de systèmes réels.

Revue critique indépendante

Conclusions les moins solides

- L'attribution à un acteur étatique ou à une personne réelle est la partie la moins solide ; elle reste LOW et n'est pas retenue comme finding établi.
- La date exacte de la première découverte est ambiguë entre les formulations du 28 et du 29 mars.
- L'exploitation réelle à grande échelle n'est pas démontrée par les sources collectées.

Affirmations dépendant d'une seule source

- Les heures des tags 5.6.0 et 5.6.1 reposent désormais sur les pages GitHub et sur les métadonnées Git [20] ; les deux proviennent du même dépôt et ne constituent pas des registres indépendants.
- L'absence d'affectation de RHEL repose principalement sur l'advisory Red Hat ; elle est valide pour le périmètre Red Hat, pas pour tout l'écosystème.
- Les détails de la première observation reposent principalement sur le rapport d'Andres Freund, qui est la source primaire appropriée mais unique pour son expérience directe.

Biais de sélection

- La collecte privilégie les sources institutionnelles et techniques anglophones, ce qui peut sous-représenter des analyses indépendantes ou des sources de distributions non incluses.
- Plusieurs sources secondaires citent les mêmes advisories ; leur convergence narrative ne doit pas être comptée comme corroboration totalement indépendante.
- Les sources postérieures à l'événement peuvent bénéficier d'informations découvertes après les premières alertes, ce qui explique certaines différences de précision.

Contradictions insuffisamment explorées

- La contradiction apparente entre dépôt et tarballs est résolue au niveau documentaire (révision du 2026-10-30) ; une comparaison artefact par artefact, octet par octet, reste à faire.
- Les différences de formulation sur RCE, bypass et exploitation devraient être comparées avec la date et le niveau de reverse engineering de chaque source.
- La portée par distribution couvre désormais Debian, Fedora/RHEL, Arch Linux, openSUSE/SUSE et Ubuntu ; les distributions non documentées restent à couvrir.

Informations qui pourraient invalider l'analyse

- Preuve que les versions ou tarballs citées ne contenaient pas le code décrit.

- Logs ou rapports montrant une exploitation réussie à grande échelle, ou au contraire démontrant l'absence vérifiable d'exploitation dans tous les environnements concernés.
- Éléments authentifiés établissant une autre cause que l'insertion malveillante dans la chaîne de publication.
- Nouvelle analyse primaire démontrant une attribution spécifique avec une chaîne de preuve indépendante.

Sources

[1] CISA

> "CISA and the open source community are responding to reports of malicious code being embedded in XZ Utils versions 5.6.0 and 5.6.1. This activity was assigned CVE-2024-3094."

[2] Openwall oss-security — Andres Freund

> "The upstream xz repository and the xz tarballs have been backdoored."

[3] XZ Utils maintainer page

> "XZ Utils 5.6.0 and 5.6.1 release tarballs contain a backdoor."

[4] OpenSSF

> "While the motivation behind this backdoor remains unknown, the intent was to compromise specific distributions, as the backdoors were only applied to DEB or RPM packages for the x86-64 architecture built with gcc and the gnu linker."

[5] Debian DSA-5649-1

> "Right now no Debian stable versions are known to be affected."

[6] Microsoft

> "On March 28, 2024 a backdoor was identified in XZ Utils."

[7] Datadog Security Labs

> "When a malicious version of the `xz-utils` library is installed, a malicious shared object (SO) file is stored on disk."

[8] GitHub release v5.6.0

> "> JiaT75 tagged this 24 Feb 08:22"

[9] GitHub release v5.6.1

> "> JiaT75 tagged this 09 Mar 08:16"

[10] CERT-EU Advisory 2024-032

> "On March 29, several companies issued a warning regarding a backdoor found in the XZ Utils software."

[11] Red Hat advisory

> "No versions of Red Hat Enterprise Linux (RHEL) are affected by this CVE."

[12] Ars Technica

> "At the moment, it's unknown if there was ever a real-world person behind this username or if Jia Tan is a completely fabricated individual."

[13] Russ Cox — Timeline of the xz open source attack

> "Over a period of over two years, an attacker using the name "Jia Tan" worked as a diligent, effective contributor to the xz compression library, eventually being granted commit access and maintainership."

[14] NIST NVD — CVE-2024-3094

> "Malicious code was discovered in the upstream tarballs of xz, starting with version 5.6.0."

[15] xzbot — notes, honeypot, and exploit demo for the xz backdoor

> "The backdoor uses a hardcoded ED448 public key for signature validation and decrypting the payload."

[16] Arch Linux — The xz package has been backdoored

> "To our knowledge the malicious code which was distributed via the release tarball never made it into the Arch Linux provided binaries, as the build script was configured to only inject the bad code in Debian/Fedora based package build environments."

[17] openSUSE — supply chain attack against xz

> "Our rolling release distribution openSUSE Tumbleweed and openSUSE MicroOS included this version between March 7 and March 28."

[18] Ubuntu Security — CVE-2024-3094

> "The affected version of xz-utils was only in noble-proposed, and was removed before migrating to noble itself. No released versions of Ubuntu were affected by this issue."

[19] Launchpad API — xz-utils publishing history for Ubuntu noble

> "5.6.0-0.2 Release Deleted created 2024-03-28T14:41:03.560483+00:00 published None superseded 2024-03-28T15:04:50.347590+00:00 removed 2024-03-29T06:10:17.845913+00:00 comment Revert to previous version."

[20] XZ Utils Git repository — commit and tag metadata (tukaani-project/xz)

> "commit cf44e4b7f5dfdbf8c78aef377c10f71e274f63c0 | author Jia Tan 2024-02-23T23:09:59+08:00 | committer Jia Tan 2024-02-23T23:09:59+08:00 | Tests: Add a few test files."

[21] xz-devel mailing-list archive — first patch from Jia Tan

> "Jia Tan Fri, 29 Oct 2021 11:29:18 -0700"